

# Artigo: MCP

O Model Context Protocol (MCP) é um padrão aberto emergente que define um protocolo unificado e bidirecional de comunicação e descoberta dinâmica entre modelos de IA e ferramentas ou recursos externos, com o objetivo de melhorar a interoperabilidade e reduzir a fragmentação entre sistemas diversos. Este paper, publicado em 2026, apresenta uma análise sistemática do MCP tanto do ponto de vista arquitetural quanto de segurança, oferecendo a primeira exploração abrangente do ecossistema.

O trabalho surge em um momento importante da evolução dos sistemas de IA. Modelos de linguagem conseguem invocar APIs externas de forma estruturada desde 2023, e desde então diversos atores como OpenAI, Google e Anthropic desenvolveram seus próprios mecanismos proprietários para integração de ferramentas. O problema é que integrar ferramentas permanece fragmentado, exigindo que desenvolvedores definam manualmente interfaces, gerenciem autenticação e lidem com lógica de execução para cada serviço. Frameworks como LangChain e LlamaIndex tentaram padronizar isso, mas cada plataforma mantém suas próprias especificações. O MCP tenta resolver essa fragmentação através de um protocolo universal baseado no Language Server Protocol.

Os autores definem a arquitetura do MCP em torno de três componentes principais. O host MCP é a aplicação de IA que executa tarefas inteligentes, como Claude Desktop ou Cursor. O cliente MCP é o intermediário que reside no host e mantém comunicação um-para-um com servidores. O servidor MCP é o responsável por expor ferramentas, recursos e prompts que permitem ao host acessar sistemas externos. O aspecto mais valioso do paper é a decomposição do ciclo de vida completo de um servidor MCP em quatro fases sequenciais: criação, implantação, operação e manutenção, abrangendo 16 atividades-chave. Essa estrutura torna evidente onde vulnerabilidades podem surgir e oferece um framework útil para pensar em segurança de forma holística.

O grande destaque do trabalho é a taxonomia abrangente de ameaças que desenvolvem. Os autores identificam quatro tipos principais de atacantes e mapeiam 16 cenários de ameaça distintos. Ataques de desenvolvedores maliciosos incluem typosquatting de namespace, onde alguém registra um servidor com nome praticamente idêntico a um legítimo para enganar usuários ou agentes de IA. Há também conflitos de nomes de ferramentas, manipulação de preferência através de linguagem persuasiva nas descrições, envenenamento de ferramentas que esconde lógica maliciosa mantendo a interface legítima, e rug pulls onde um servidor publicado como benigno é alterado maliciosamente em atualizações subsequentes. Atacantes externos podem fazer spoofing de instaladores, distribuindo pacotes modificados, ou executar injeção indireta de prompts, embutindo instruções maliciosas em dados externos que modelos recuperam via ferramentas MCP. Usuários maliciosos podem roubar credenciais armazenadas em arquivos de configuração, escapar de sandboxes, abusar do encadeamento de ferramentas para exfiltrar dados passo a passo, ou obter acesso não autorizado explorando falhas de autenticação. Finalmente, falhas de segurança incluem redeploying versões vulneráveis, persistência de privilégios após atualizações onde credenciais

revogadas continuam válidas, e drift de configuração onde ajustes não coordenados desviam do baseline de segurança.

Além da análise teórica, o paper examina a adoção real do MCP no mercado. Encontram que líderes como Anthropic, OpenAI, Google e empresas chinesas como Baidu integraram MCP em seus ecossistemas, assim como plataformas em nuvem como Cloudflare e provedores de ferramentas de desenvolvimento como Cursor e JetBrains. Porém, embora haja impulso claro, o ecossistema MCP geral permanece desigual em maturidade. Muitos servidores comunitários são pequenos experimentos ou protótipos iniciais sem documentação padronizada ou manutenção ativa. Uma descoberta prática particularmente reveladora: testando 300 servidores listados em uma das maiores coleções públicas de MCP, encontraram que 30 nem eram realmente sobre o Model Context Protocol e 18 estavam indisponíveis no momento da inspeção. Isso sugere que diretórios comunitários podem superestimar seus números efetivos.

. O paper é impressionante em escopo e oferece várias contribuições valiosas para a comunidade acadêmica trabalhando com IA aumentada com ferramentas. No entanto, algumas das ameaças descritas não são realmente únicas ao MCP, mas sim manifestações de problemas bem conhecidos em integração de software e segurança de APIs adaptadas para o contexto de modelos de linguagem. Typosquatting, por exemplo, é um problema historicamente documentado em npm, PyPI e outras plataformas. O envenenamento de ferramentas através de instruções escondidas em metadados é uma variante da injeção indireta de prompts que já foi estudada. Isso não diminui o valor do trabalho, mas indica que muito da segurança do MCP virá de aplicar boas práticas existentes no novo contexto.

O trabalho oferece uma base sólida para futuras pesquisas. Eles identificam corretamente que o MCP ainda está em estágios iniciais e que áreas como descoberta de ferramentas, implantação remota e mecanismos de confiança precisam de desenvolvimento substancial. As recomendações para padronizar gerenciamento de pacotes, implementar um registro oficial verificado, e desenvolver frameworks unificados de autenticação são práticas e realistas. Para estudantes e pesquisadores, este paper serve tanto como mapa da paisagem atual quanto como agenda para trabalho futuro na interseção de segurança de software e sistemas de IA aumentados com ferramentas.